Sheriff case SHF-20261017-e4d7f6

Independent re-audit of SHF-20261016-3caa6f, followed by the deep sweep of crypto-autoresearcher, crypto and cryptanalysis on `origin/main` (2026-10-17). This is an audit record. It changes no research state and repairs nothing. Verdicts are in `findings.yaml` (`check-case` passes), with the per-original-finding table in `original_finding_verdicts`. The full text is in `REPORT.md`.

Result: 19 of 26 findings are fixed, 5 are partially fixed (S1, S2, L5, L6, K2), 2 are not fixed (M2, R1), and none regressed. Blocker S1 is not cleared: both STARK verifiers still accept proofs of false statements.

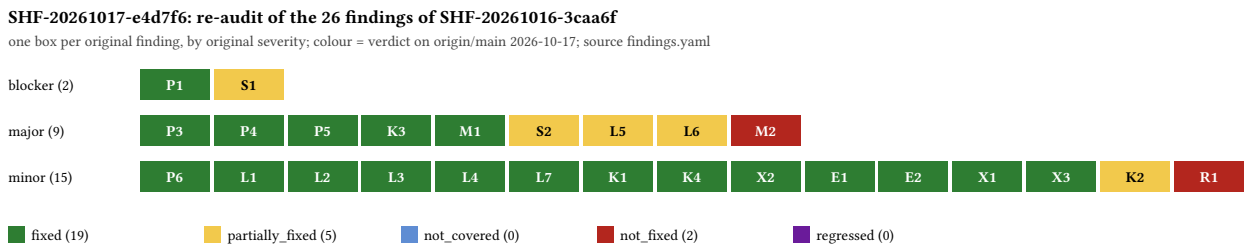


Figure 1: The 26 original findings by severity, coloured by this re-audit's verdict.

Scope

repository	commit	how
crypto-autoresearcher	`ea8a9f6f1d` origin/main	in place
crypto	`42b9ca8a5a` origin/main	sparse partial clone (anonymous read); `ecbench` built
cryptanalysis	`4fa77724f6` origin/main	sparse partial clone (anonymous read)

- The canary passed (15/15, 0 false positives). The instrument sha256 is `f91dd78f`….
- crypto could not be attached to the session (`add_repo` was refused), so its CI runs are not covered.
- Disk was about 4 GB at best, so the Lean builds were module-level only.

Prior (`prior.md`, written before any fix was read): S1 partially fixed, L1 possibly not compiling, L6 workflows possibly never run, M2 at or above 287, R1 not fixed. All but L1 were confirmed; L1 builds.

Blocker V1: S1 is only partially fixed

The four original mutants are rejected, and `cargo test zk::stark` passes 18 tests. Of 31 new mutants, 9 are accepted; the session re-ran them and got the same nine:

- **stark_v2, frozen heart.** `transcript_to_fri` (`stark_v2.rs:226-240`) absorbs only the tag and the two commitments, never the public boundary, n, the AIR, β or q. A prover picks the public input after α_1 and α_2, and `verify` accepts a false statement. This holds in both configurations and for a row-6 boundary; the v+1 control is rejected. The forgery is deterministic.
- **stark v1.** The verifier takes q from the proof. q=1 forgeries, truncation to 3 queries, two-row grinding at q=20 (attempt 107) and zero-fold FRI are all accepted.
- Nothing outside `src/zk` uses these modules.
- **Fix:** absorb the full statement before α_1, fix q and the FRI depth in the verifier, and add these mutants as tests. Until then, mark both modules unsound.

Verdicts on the original findings

id	sev	verdict	basis (re-run in this case)
S1	blocker	**partially fixed**	0/4 original mutants accepted; 9/31 new accepted, incl. 3 frozen-heart forgeries (V1)
P1	blocker	fixed	correction, PDF and re-run consistent; $n^4 > f64::MAX$ only for secp256k1
S2	major	partially fixed	old formula gone; new 240/40-bit claim does not hold (V2)
L5	major	partially fixed	narrowed; TransferBound and README §5 still overreach
L6	major	partially fixed	conductor_gap built here, `[propext]`; S3Roots and CI not covered; no log committed
P3	major	fixed	26,278 / 9,864 / 0 violations re-derived
P4	major	fixed	330 of 669 primes; CM-73 set reproduced
P5	major	fixed	abstract carries assumptions and ranges
K3	major	fixed	setup = cold – online on every row; blind n=83 gives 9.66731
M1	major	fixed	hashes match the registry; one-indent diff; hygiene passes
M2	major	**not fixed**	330 new ledger errors (claimed 287); no triage; gate disabled
L1	minor	fixed	built here (v4.35.0-rc1, Mathlib 7fa22735): `[propext]`; proves-too-much fails

L2	minor	fixed	S ∈ E(k), dated correction
L3	minor	fixed	Leak kernel-checked (built here); `replay_ok` disclosed
L4	minor	fixed	5 cells at −1 and 15 at 0; PDF regenerated
L7	minor	fixed	"its root identity, Proposition 1, is proved in Lean"
P6	minor	fixed	artifacts cited; hashes match; replay identical
K1	minor	fixed	wall-time label; 1.4773 operation ratio
K2	minor	partially fixed	disclosed; no group-op counts, so no GAE band
K4	minor	fixed	paired within-run deltas recorded
R1	minor	**not fixed**	no other-host replay; disclosure only
X2	minor	fixed	2,681 archives, 0 problems
E1	minor	fixed	256/256 sessions pass; sessions untouched
E2	minor	fixed	CI enumerates sessions by schema
X1	minor	fixed	re-audited here with fresh nonces: clean
X3	minor	fixed	instrument recorded; new defects filed as I1

New and residual findings

id	sev	what
V1	blocker	frozen heart in stark_v2; prover-chosen q, truncation, grinding in v1
V2	major	the stated 240/40-bit bound does not hold for this verifier
CI1	major	19 of 22 crypto-autoresearcher workflows disabled (validate, lean-verification) since 2026-10-12; the fixes ran only Cursor checks
M2-R	major	330 ledger errors and rising; 319 vs 287 unexplained
V3	minor	malleability, a panic on oversize values, no out-of-domain sample, test gaps
L-N1/2/7/8/9	minor	trusted-native list; L5 residue; no committed logs; in-place edit; theorem name
P-N1/2/4/5/6/7	minor	P-521 mechanism unsupported; probe counts; wording; provenance line; stale twin; "exactly"
E1-R, R1-R	minor	unbound never-finalised sessions; no other-host replay
K-N1..4	minor	no GAE counts; mixed ratchet fields; gzip sentence; roundings
I1	minor	instrument: `tree_digest` constant; sessions checker sparse-blind; sparse coverage loss

Sweep

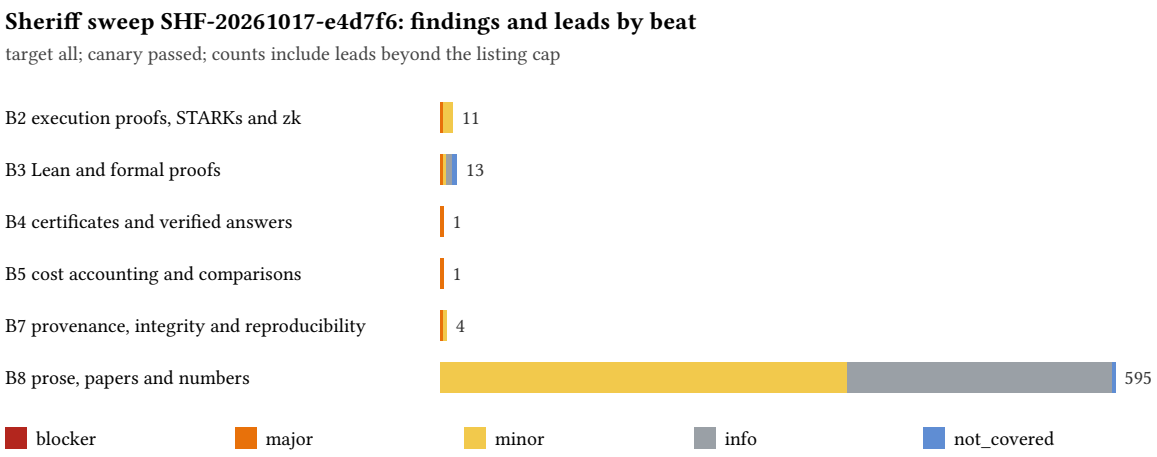


Figure 2: Deterministic sweep leads by beat (sweep.json).

The sweep leads were handled as follows:

- **Sparse artefacts, dismissed after re-running:** `zk-stark-tests`, `curve-names`, `ecbench-bounds`, `fb-archive` and `fb-refs`.
- **Pre-existing, not examined in this case:** groth16 has no negative test; plonk discards `omega`.
- **Coverage loss:** 227 new untraced-number leads, all in papers the fixes did not touch, whose artifacts are outside the sparse sets.
- **Papers changed by the fixes:** their untraced-number leads went down (LLL 7⟶0, structural 23⟶0, rootfinding 19⟶4, semaev 17⟶6).

Not covered

- **CI runs in crypto and cryptanalysis:** attach both repositories and list the workflow runs.
- **S3Roots build and audit:** about 6 GB of disk needed.
- **The whole `formal/` build, `verify_formal_targets` and lean4checker.**

- **The 287 baseline:** a full worktree at `ecdb13bdff`.
- **Papers outside the sparse sets.**
- **`make check` for the papers.**
- **R1:** a replay on another host class.

What this case does not establish

- That any `src/zk` STARK verifier is sound. The opposite is shown.
- That the crypto or cryptanalysis CI workflows ran.
- That the whole `formal/` workspace builds.
- Any execution proof.
- Anything outside the sparse checkouts.
- The cause of the 319-versus-287 ledger gap.

Readers: validator (B2, `readers/stark.yaml`), validator (B3, `readers/lean.yaml`), validator (B8, `readers/papers.yaml`; it discloses one commit message seen after its recount), and red-team (B5, `readers/costmodel.yaml`). Reader paths under `/tmp/...` refer to the staging copy, which is mirrored here under `scripts/readers/`.